

RULES OF ENGAGEMENT (RoE)

Client: Smith & Associates Law Firm

Consultant: Mohamad Ghaoui, Lead Security Tester

Date: May 25, 2026

Project: Network Security Penetration Test

1. Introduction

Hello Smith & Associates Team,

The purpose of this document is to agree on the rules for your upcoming security test. Our goal is to find weaknesses in your computer network before bad actors do, while ensuring we do this safely without disrupting your daily legal work or compromising your clients' confidentiality.

2. Scope of Work (What We Will Test)

We are only authorized to test the specific systems listed below. Anything not explicitly listed here is strictly off-limits and will not be touched during this engagement.

- **Main Public Website:** www.smithandassociates-law.fake
- **External Email Server:** mail.smithandassociates-law.fake
- **Internal Office IP Range:** 192.168.10.1 through 192.168.10.255

3. Methods (How We Will Test)

To keep your business running smoothly, we will use safe, industry-standard testing methods.

- **Allowed Tools (In-Bounds):** We will use network mapping tools (like Nmap) and passive vulnerability scanners to identify open ports and outdated software. We will also perform manual login testing on your web applications to check for password weaknesses.
- **Forbidden Tools (Out-of-Bounds):** We will **not** use Denial of Service (DDoS) attacks, as we do not want to crash your servers or stop your staff from working. We will also **not** use Social Engineering (such as phishing emails, dropping USB drives, or calling employees for passwords) during this specific phase.

4. Data Handling (How We Protect Your Secrets)

As a law firm, your client data is legally protected and highly sensitive. If our test finds a vulnerability that allows access to your private files, we will follow these strict rules to ensure legal compliance:

- We will **never** download, copy, open, or read your actual client files, emails, or financial records.
- To prove the vulnerability exists, we will only take a screenshot of the top-level folder directory (showing the file names or structure) as proof of access.
- Any evidence we collect will be stored on a hardware-encrypted drive, shared only with the Managing Partner via an encrypted channel, and securely destroyed 30 days after the project concludes.

Client Approval & Acknowledgment:

John Smith

Managing Partner, Smith & Associates

Date: _____

AUTHORIZATION TO CONDUCT SECURITY TESTING

(Permission to Test - PTT)

Date of Issue: May 25, 2026

Valid Testing Dates: June 1, 2026 – June 5, 2026

TO WHOM IT MAY CONCERN:

This document serves as formal authorization for **Mohamad Ghaoui** and his designated security team to perform authorized penetration testing and security auditing on the computer networks, physical offices, and digital facilities belonging to **Smith & Associates Law Firm**.

The bearer of this letter is acting under a signed, legally binding Master Services Agreement and Rules of Engagement with our firm. They have explicit permission to bypass security controls, scan networks, and test systems specifically listed in our agreed-upon scope.

This is an authorized, simulated cyber-security assessment. The bearer is not committing a crime, trespassing, or violating any company policies, state laws (RCW 9A.90), or federal laws (CFAA).

If you have stopped the bearer of this letter or have any questions about their presence or activities, please immediately contact the managing partners below for verification before taking any further action:

Client Verification Contacts (Available 24/7 during testing window):

Name: John Smith

Title: Managing Partner, Smith & Associates

Phone: (555) 019-8372

Email: jsmith@smithandassociates-law.fake

Name: Jane Doe

Title: IT Director, Smith & Associates

Phone: (555) 019-9921

Email: jdoe@smithandassociates-law.fake

Authorized By:

John Smith

Managing Partner, Smith & Associates

Date: _____

Mohamad Ghaoui

Lead Security Tester

Date: _____